Guía de estudio LINCE

20 preguntas del test con la respuesta correcta y su explicación

Resumen rápido: datos clave

ETR	Evaluation Technical Report (CCN-STIC-2004). Veredicto PASA / FALLA.
ST	Security Target (CCN-STIC-2003). Alcance, hipótesis, activos, dimensiones, amenazas, RFS y SF.
TOE	Target of Evaluation = producto + versión + configuración.
Esfuerzo / plazo	25 jornadas en unas 8 semanas.
Módulos opcionales	MEC (criptográfica), MCF (código fuente), MEB (biométrica): ~5 jornadas / 2 semanas cada uno.
Actividades núcleo	Pruebas funcionales, análisis de vulnerabilidades y pruebas de penetración.
Laboratorio	Acreditado ISO/IEC 17025 y autorizado por el OC dentro del ENECSTI.
Organismo de Certificación	Parte del CCN, único. Revisa las pruebas y emite el certificado.
Dimensiones ENS	Confidencialidad, integridad, disponibilidad, trazabilidad y autenticidad.
Categorías ENS	Básica, media y alta. La básica no está en el CPSTIC ni tiene LINCE.
Categoría ALTA	LINCE vigente en MEDIA + cripto ENS ALTA + RFS adicionales + revisión anual.
Veredicto FALLA	Observation Report (OR); 6 meses para resolver y emitir nuevo ETR.
Caducidad	2,5 años sin soporte / 5 años con soporte. Después, evaluación nueva.
Nueva versión	No está certificada; evaluación por análisis diferencial.
Certificación vs CPSTIC	No son lo mismo: hay que solicitar la cualificación e inclusión.
Taxonomía (CCN-STIC-140)	Si se declara, hay que cumplir todos sus RFS y SF.
LINCE vs Common Criteria	LINCE: más rápida, menor alcance, más práctica, reconocimiento nacional.

Preguntas y respuestas

1. ¿Qué es el ETR?

Respuesta correcta: Un documento autocontenido de la evaluación, con trazabilidad de las pruebas, resultados y veredicto PASA o FALLA

El ETR (Evaluation Technical Report), cuya plantilla es la CCN-STIC-2004, es un documento autocontenido de la evaluación que deja trazabilidad completa de las pruebas realizadas, recoge los resultados y emite un veredicto PASA o FALLA. La trazabilidad la exige la ISO/IEC 17025.

2. ¿Cuál es el esfuerzo y el plazo de referencia de una evaluación LINCE estándar?

Respuesta correcta: 25 jornadas en 8 semanas

La presentación indica 25 jornadas de esfuerzo distribuidas en unas 8 semanas.

3. ¿Qué se exige para que una certificación LINCE sea válida para la categoría ALTA del ENS?

Respuesta correcta: Una LINCE vigente en MEDIA, criptografía conforme a ENS ALTA, cobertura de los RFS adicionales y revisión anual

Se requiere una LINCE vigente en MEDIA, criptografía conforme a los requisitos de ENS ALTA, cubrir los RFS adicionales que la categoría ALTA exige y una revisión anual de análisis de vulnerabilidades y pruebas de penetración.

4. ¿Qué tres actividades prácticas constituyen el núcleo de una evaluación LINCE?

Respuesta correcta: Pruebas funcionales, análisis de vulnerabilidades y pruebas de penetración

La evaluación se apoya en pruebas funcionales, análisis de vulnerabilidades y pruebas de penetración.

5. ¿Qué caracteriza al laboratorio que realiza la evaluación?

Respuesta correcta: Está acreditado según la ISO/IEC 17025 y autorizado por el OC dentro del ENECSTI

Es un laboratorio acreditado conforme a la ISO/IEC 17025 y autorizado por el Organismo de Certificación dentro del ENECSTI. Elabora la ST junto al fabricante, revisa las guías y ejecuta las pruebas funcionales, el análisis de vulnerabilidades y las pruebas de penetración.

6. ¿Cuál de las siguientes afirmaciones describe correctamente qué es LINCE?

Respuesta correcta: Es una metodología y certificación desarrollada por el CCN para niveles de amenaza básico o sustancial, complementaria a Common Criteria

LINCE (Certificación Nacional Esencial de Seguridad) es una metodología y certificación desarrollada por el CCN, orientada a niveles de amenaza básico o sustancial y complementaria a Common Criteria.

7. ¿Qué es la ST y qué recoge?

Respuesta correcta: El Security Target: documento que define alcance, hipótesis, activos, dimensiones, amenazas y los RFS y SF del TOE

La ST (Security Target), cuya plantilla es la CCN-STIC-2003, define el alcance del TOE y su entorno operacional, hipótesis, activos protegidos, dimensiones de seguridad, RFS y SF, amenazas, librerías de terceros, taxonomía, módulos adicionales y guías.

8. ¿Qué es el CPSTIC?

Respuesta correcta: El Catálogo de Productos y Servicios de Seguridad de las TIC, mantenido por el CCN

CPSTIC es el Catálogo de Productos y Servicios de Seguridad de las Tecnologías de la Información y la Comunicación, mantenido por el CCN, que clasifica los productos por casos de uso o familias y por categorías del ENS.

9. ¿A qué corresponden los módulos opcionales MEC, MCF y MEB?

Respuesta correcta: Evaluación criptográfica, revisión de código fuente y evaluación biométrica

MEC = evaluación criptográfica; MCF = revisión de código fuente; MEB = evaluación biométrica. Son opcionales y cada uno añade unas 5 jornadas / 2 semanas.

10. ¿Qué es el TOE en una evaluación LINCE?

Respuesta correcta: El Target of Evaluation: producto, versión y configuración concretos que se evalúan

TOE (Target of Evaluation) es lo que se evalúa: un producto concreto, en una versión concreta y con una configuración concreta.

11. Si el veredicto del ETR es FALLA, ¿qué ocurre?

Respuesta correcta: Se emite un Observation Report con las no conformidades y hay 6 meses para resolverlas y emitir un nuevo ETR

Se emite un OR (Observation Report) con las no conformidades detalladas. El fabricante debe resolverlas y el laboratorio emitir un nuevo ETR en un plazo de 6 meses desde el primero; si no, hay que empezar una evaluación desde cero.

12. Si en la ST se declara una taxonomía (CCN-STIC-140), ¿qué implica?

Respuesta correcta: Que deben cumplirse todos los RFS y SF de esa taxonomía

Declarar una taxonomía obliga a cumplir todos sus RFS y SF. Si algún requisito no aplica al producto, no puede cumplirse al 100 % y por tanto no debe declararse esa taxonomía en la ST.

13. ¿Cuáles son las categorías del ENS y qué ocurre con la más baja?

Respuesta correcta: Básica, media y alta; la básica no está incluida en el CPSTIC ni se evalúa con LINCE

Las categorías son básica, media y alta. La básica no está incluida en el CPSTIC ni dispone de metodología LINCE para evaluarla.

14. ¿Por qué resulta interesante para un fabricante certificarse en LINCE?

Respuesta correcta: Porque le permite demostrar un nivel de seguridad acorde al ENS y optar a la inclusión en el CPSTIC, catálogo usado por el sector público

Permite demostrar un nivel de seguridad acorde al ENS y solicitar la inclusión en el CPSTIC, catálogo del que se sirven el sector público y las empresas que le prestan servicios.

15. ¿Cuál de las siguientes NO es una dimensión de seguridad del ENS según la presentación?

Respuesta correcta: Escalabilidad

Las dimensiones son confidencialidad, integridad, disponibilidad, trazabilidad y autenticidad. La escalabilidad no es una de ellas. Además, no es obligatorio evaluar todas en una evaluación LINCE.

16. Frente a Common Criteria, ¿cómo se caracteriza LINCE?

Respuesta correcta: Más rápida, de menor alcance, con pruebas más prácticas y reconocimiento nacional

LINCE es una evaluación más rápida y de menor alcance, con una metodología de pruebas más práctica y un reconocimiento nacional. Common Criteria tiene mayor profundidad, un enfoque más sistemático y documental, y reconocimiento basado en acuerdos entre países.

17. ¿Cuál es la función del Organismo de Certificación?

Respuesta correcta: Revisar las pruebas realizadas por el laboratorio y emitir el certificado

El Organismo de Certificación, que forma parte del CCN, revisa las pruebas realizadas por el laboratorio y emite el certificado. Pese a su nombre, es único.

18. El fabricante publica una nueva versión del producto ya certificado. ¿Qué sucede?

Respuesta correcta: La nueva versión no está certificada; para incluirla hace falta una evaluación basada en análisis diferencial

Como el TOE es producto + versión + configuración, la nueva versión no está certificada ni forma parte del catálogo. Para incluirla se realiza una evaluación basada en un análisis diferencial entre la versión certificada y la nueva.

19. ¿Qué relación existe entre obtener la certificación LINCE y figurar en el CPSTIC?

Respuesta correcta: No son equivalentes: tras certificarse hay que solicitar la cualificación e inclusión en el CPSTIC

No son equivalentes: una vez certificado, el fabricante debe solicitar la cualificación e inclusión del producto en una familia del CPSTIC. Habitualmente los requisitos se acuerdan con el CPSTIC antes de la evaluación.

20. ¿Qué sucede cuando caduca un certificado LINCE?

Respuesta correcta: Caduca a los 2 años y medio sin soporte o a los 5 años con soporte, y hace falta una evaluación nueva

La caducidad es de 2 años y medio si el producto no tiene soporte y de 5 años si lo tiene. Al caducar, el producto deja de figurar en el catálogo y es necesaria una evaluación nueva.